EXPERIMENT 8

Configuring a Hospital Appointment Booking & Patient Management Application with Role-Based Access Control (RBAC) in Zoho Creator

Name: Akshaya | Roll Number: 241401009

Title

Design and Implementation of a Hospital Appointment Booking & Patient Management Application with User Permissions, Roles, Role Hierarchy and Data Sharing in Zoho Creator.

Aim

To build an appointment-tracking application in Zoho Creator using a structured 13-field booking form (Appointment_Booking_Form) and report (Appointment_Booking_Report), and to implement granular role-based access control through a three-level role hierarchy and a custom Read Only data-sharing rule.

Objectives

- To design Appointment_Booking_Form with 13 Basic Fields grouped into four layout panels: Identity, Contact, Preferences and Scheduling.
- To create Appointment_Booking_Report and a dashboard showing bookings, slot capacity utilised and department-wise patient distribution.
- To define the role hierarchy Hospital Director → Department Head → Front Desk Coordinator.
- To configure a data-sharing rule from Department Head to Front Desk Coordinator with Read Only access.
- To understand how RBAC separates data ownership from data visibility.

Software / Tools Required

- Zoho Creator (web-based low-code application development platform)
- Hospital Appointment Booking application created in Zoho Creator
- Web browser with an active internet connection
- Zoho account with access to the application in Edit mode

Introduction / Theory

User Management in Zoho Creator

User management decides who can access an application and what each person may see and do within it. Users are added to an application and associated with permission sets (profiles) and roles; together these control access to forms, reports, pages and records. In the Settings area, the User Permissions section groups these controls under three tabs: Permissions, Roles and Data Sharing.

Role-Based Access Control (RBAC)

RBAC is an access-control model in which rights are assigned to roles instead of individual users, and users acquire rights through the roles they hold. It simplifies administration, supports the principle of least privilege, improves data security and keeps the access policy consistent and easy to audit.

Key Concepts

Concept	Description
Users	Individuals added to the application who sign in to work with its forms, reports and data.

241401009

Concept	Description
Permissions	Named permission sets (profiles) defining what a user may do with components. This application lists *Department_Admin_Access*, *Read* and *Write*.
Roles	Positions in the organisational structure (Hospital Director, Department Head, Front Desk Coordinator) that determine a user's place in the hierarchy and the visibility of records.
Role Hierarchy	A tree in which each role reports to another. A higher role can generally view the records of roles beneath it; the reverse does not apply.
Data Sharing	Share rules that extend record visibility beyond the hierarchy, from one role or user to another, with a defined level of access (Read Only or Read/Write).

Application Specifications

Parameter	Detail
Application Name	Hospital Appointment Booking & Patient Management
Form Name	Appointment_Booking_Form
Report Name	Appointment_Booking_Report
Form Architecture	13 Basic Fields in 4 layout panels (Identity, Contact, Preferences, Scheduling)
Role Hierarchy	Hospital Director → Department Head → Front Desk Coordinator
Custom Sharing Rule	Department Head → Front Desk Coordinator (Read Only)

Procedure

1. Sign in to Zoho Creator. The home page lists the available applications. Locate the **Hospital Appointment Booking** application (Figure 8.1).

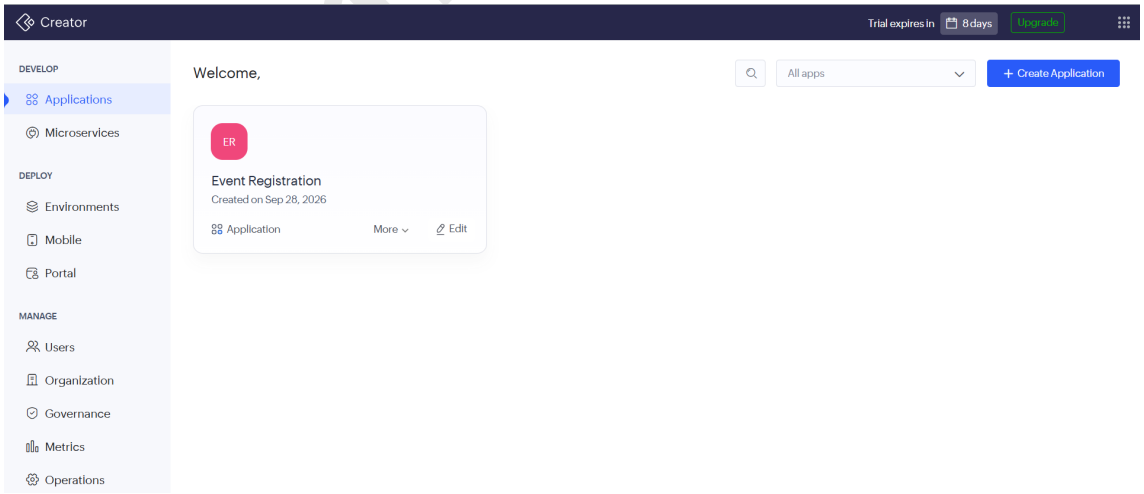


Figure 8.1: Zoho Creator Home – Hospital Appointment Booking Application

2. Open the application to view its dashboard, which contains the **All Appointments** report, the *Total Appointments* and *Slot Capacity Utilised* tiles and the patient charts (Figure 8.2).

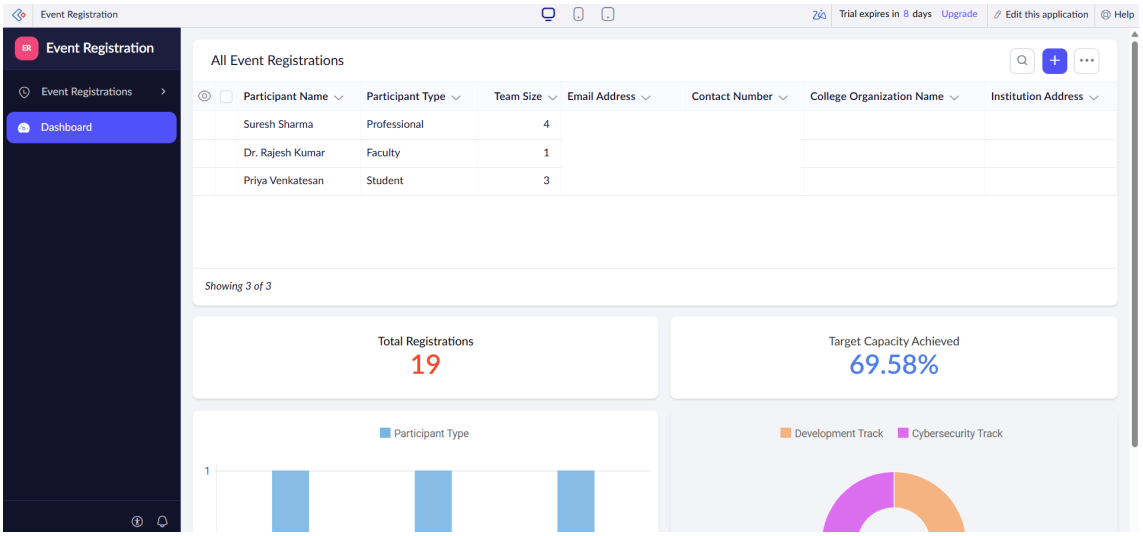


Figure 8.2: Hospital Appointment Booking Application – Access Mode

3. Enter Edit mode by selecting **Edit** on the application card (Figure 8.1) or **Edit this application** at the top-right (Figure 8.2).
4. Select the **Settings** tab from the top navigation bar (Design, Workflow, Settings).
5. Under the PERMISSIONS group, select **User Permissions**. The Users page is displayed with the tabs Permissions, Roles and Data Sharing.
6. Study the **Permissions** tab. Three permission sets are listed: *Department_Admin_Access*, *Read* and *Write*. An **Add Permission** button is also provided (Figure 8.3).

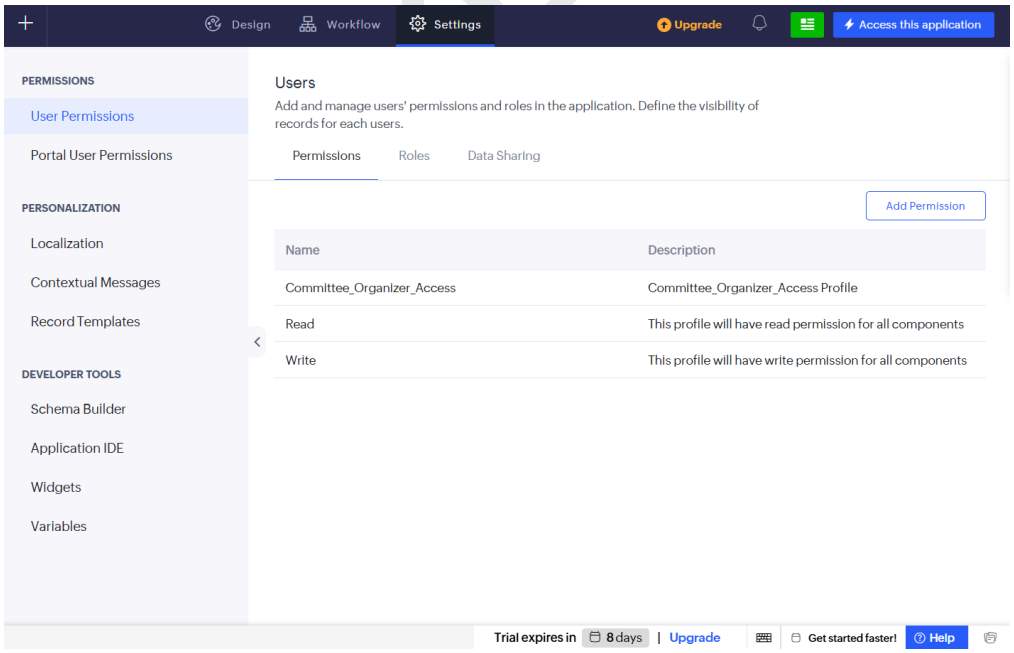


Figure 8.3: User Permissions – Permissions Section

7. Select the **Roles** tab and arrange the role tree as **Hospital Director → Department Head → Front Desk Coordinator**. The Expand All, Collapse All, Manage Role Hierarchy and Add Role options are available (Figure 8.4).

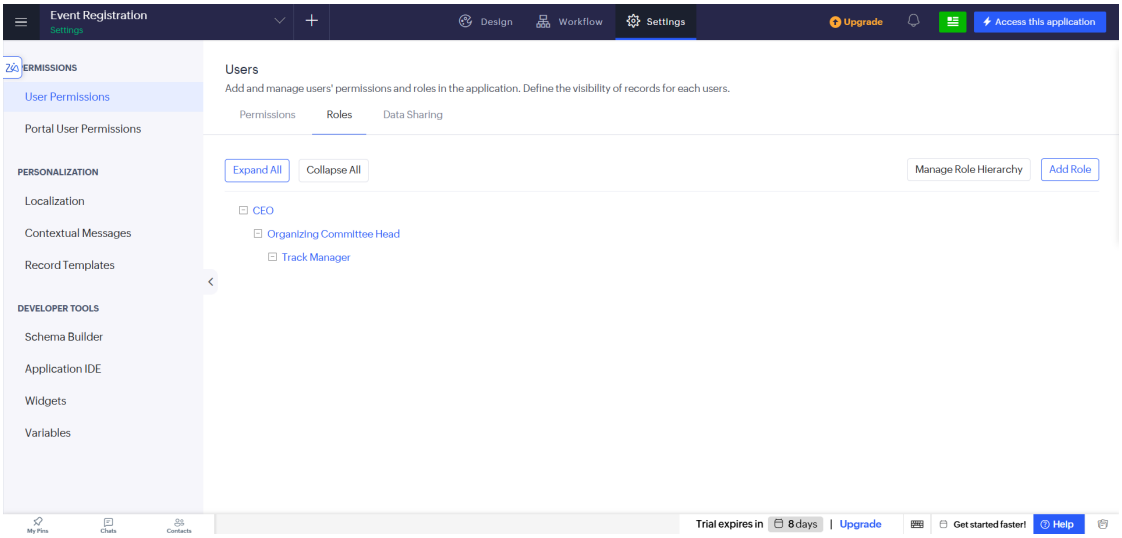


Figure 8.4: Roles and Role Hierarchy

8. Select the **Data Sharing** tab and choose **New Share Rule**. Enter Name: *Appointment_Booking_Form*; Form: *Appointment Booking*; Records shared from: *Roles*. The dropdown offers Roles, Roles and Subordinates, and Users (Figure 8.5).

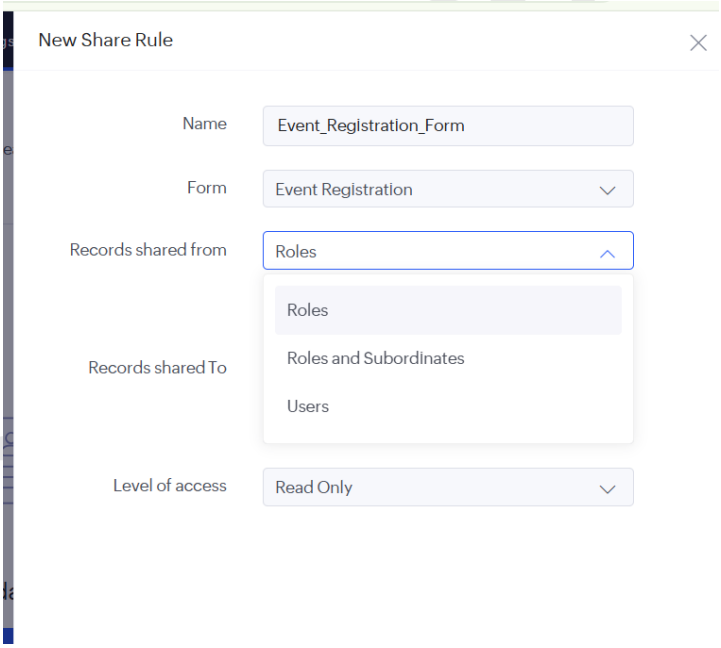


Figure 8.5: New Share Rule – Rule Configuration

9. Set Records shared from → Roles → *Department Head*; Records shared To → Roles → *Front Desk Coordinator*; Level of access → **Read Only**.

10. Select **Save**. The rule appears in the Data Sharing list and can be reopened with Edit Sharing Rule (Figure 8.6).

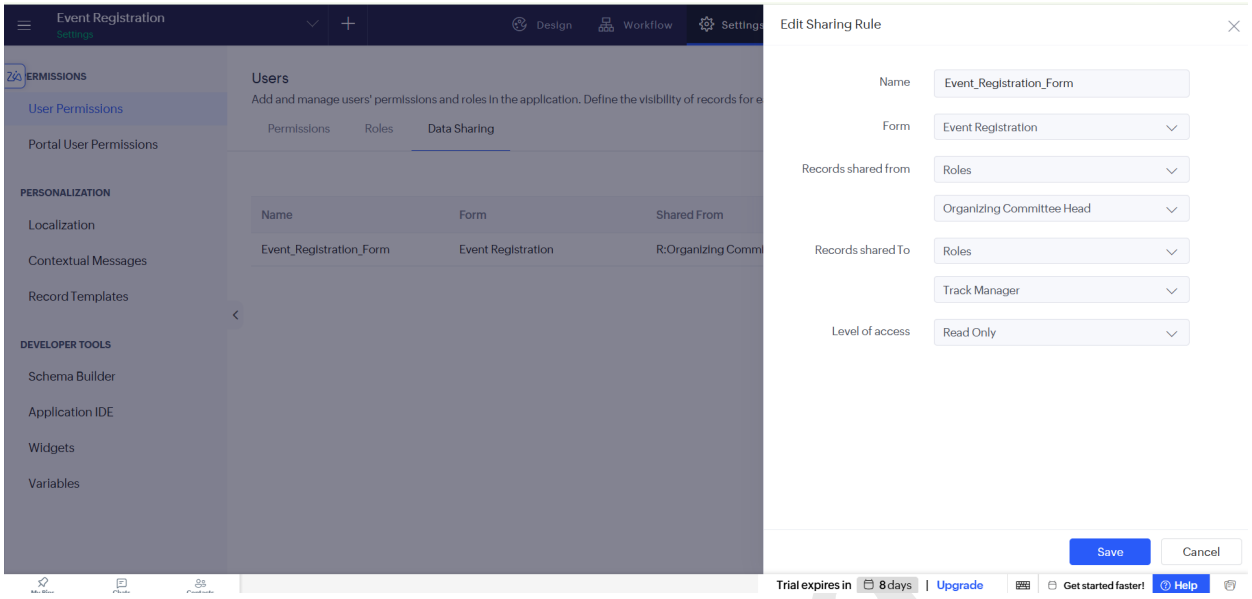


Figure 8.6: Configured Data Sharing Rule (Department Head → Front Desk Coordinator, Read Only)

Data Sharing

The application follows a layered model: **Form** (Appointment_Booking_Form) → **Report** (Appointment_Booking_Report) → **Dashboard** → **Security Layer** (Permissions, Roles, Data Sharing). The role hierarchy runs from the **Hospital Director** (overall oversight) to the **Department Head** (department-wide management) and then the **Front Desk Coordinator** (day-to-day scheduling operations). By default the hierarchy gives only upward visibility: higher roles see the records of the roles below them, but not the reverse.

The custom data-sharing rule shares Appointment_Booking_Form records from the *Department Head* role to the *Front Desk Coordinator* role at **Read Only** level. Read Only preserves data security because Front Desk Coordinators can view the appointment details they need for scheduling (patient names, departments, slots, contact information) but cannot edit or delete them, so the records held by the Department Head remain the single source of truth and cannot be altered downstream, whether by accident or deliberately. It enforces least privilege by granting visibility without modification rights, keeps the scope directional (Head → Coordinator) so access never flows upward or sideways, and leaves a single named rule in the Data Sharing list that documents who can see what, and at what level, making the policy easy to audit.

RBAC Working

Level	Role	Intended Function
1 (Top)	Hospital Director	Overall authority; able to view the records of roles reporting to it.
2	Department Head	Manages the whole department; owns the master appointment records.
3	Front Desk Coordinator	Handles scheduling for the department; views shared appointments read-only.

- Users in the Front Desk Coordinator role work with appointment records according to their permission set.
- Because Front Desk Coordinator reports to the Department Head, who reports to the Hospital Director, higher roles can view the records of the roles below them.
- Lower roles do not automatically gain access to higher-role records; the Read Only share rule grants it in a controlled way.
- The permission sets (Department_Admin_Access, Read, Write) further limit the operations each user may carry out.

Result

The following were successfully carried out in the Hospital Appointment Booking application:

- The Hospital Appointment Booking application, with Appointment_Booking_Form and Appointment_Booking_Report, was opened and its dashboard viewed.
- The permission sets Department_Admin_Access, Read and Write were studied in User Permissions.
- The role hierarchy Hospital Director → Department Head → Front Desk Coordinator was created.
- A data-sharing rule from Department Head to Front Desk Coordinator with Read Only access was configured and saved.

Conclusion

The experiment demonstrated how permissions, roles, role hierarchy and data sharing together form a role-based access control mechanism in Zoho Creator. Structured booking with typed fields replaces unstructured appointment requests (spreadsheets, chat messages and free-text emails) with clean, consistent and analysable data. The three-level hierarchy and the directional Read Only share rule keep information channels isolated: Front Desk Coordinators see only what they need and cannot alter master records, while the Hospital Director and Department Head retain oversight. The result is a secure, auditable and scalable hospital appointment-management framework.

241401009